

ASSIGNMENT 2: INTEGRATED ETHICAL HACKING REPORT

Framework: PTES, NIST SP 800-115, OWASP WSTG v4.2 · **Course Code:** 2311CS040137-EH
Engagement Scope: Localized Sandboxed Lab Perimeter | **Date:** September 22, 2026

1. Executive Summary

A full-lifecycle security assessment and penetration test was conducted across the target network and web perimeter. The engagement progressed through all 7 ethical hacking phases: Reconnaissance, Port Scanning, Service Enumeration, Vulnerability Analysis, Controlled Exploitation, Defensive Remediation, and Automated Retesting. The assessment initially identified 8 vulnerabilities (1 Critical, 4 High, 3 Medium). Following defensive hardening, 100% of findings were verified as REMEDIATED.

2. Ethical Hacking Lifecycle Progression

Phase	Focus Area	Key Tools Used	Deliverables & Outcome
01. Recon	Footprinting & Profiling	recon_target.py, DNS resolver	Identified host 127.0.0.1, Python/WSGI stack
02. Scanning	Port & Service Discovery	nmap_runner.py, Nmap 7.94	Open ports: 5000 (Dash), 5001 (API), 8080 (DVWA)
03. Enum	Web Directory Fuzzing	web_enum.py, cURL	Discovered /api/vulnerable/login & search routes
04. Analysis	CVSS Scoring & Triage	vuln_scanner.py, CWE catalog	8 Valid vulnerabilities confirmed; 4 false positives discarded
05. Exploit	Controlled PoCs	Custom Python PoC scripts	Demonstrated auth bypass and account data theft
06. Patch	Defensive Hardening	patch_auth.py, HTTP headers	Injected CSP/HSTS headers & parameterized queries
07. Retest	Automated Verification	retest_all.py regression runner	100% of attack vectors verified closed

3. Discovered Vulnerability Ledger & CVSS Scoring

ID	Vulnerability Title	CVSS	Severity	CWE / OWASP	Status
VULN-001	SQL Injection in Authentication Service (Authentication Bypass)	9.8	CRITICAL	CWE-89	REMEDIATED
VULN-002	UNION-Based SQL Injection in Product Search Service	8.6	HIGH	CWE-89	REMEDIATED
VULN-003	Numeric Parameter SQL Injection & Information Disclosure	7.5	HIGH	CWE-89 / CWE-209	REMEDIATED
VULN-004	Missing HTTP Security Headers (HSTS, CSP, X-Frame-Options)	6.5	MEDIUM	CWE-1021 / CWE-693	REMEDIATED
VULN-005	Verbose Server Software & Technology Fingerprint Disclosure	5.3	MEDIUM	CWE-200	REMEDIATED
VULN-006	Unauthenticated Administrative Dashboard Route Exposure	8.2	HIGH	CWE-306	REMEDIATED
VULN-007	Insecure Direct Object Reference (IDOR) in User Profile Data	7.5	HIGH	CWE-639	REMEDIATED
VULN-008	Weak Credential Hashing & Lack of Salt in Legacy Auth Mock	5.9	MEDIUM	CWE-328 / CWE-916	REMEDIATED

4. Automated Retest & Verification Matrix

ID	Target Vulnerability	Baseline State (Pre-Patch)	Remediated State (Post-Patch)	Result
VULN-001	Auth Bypass SQLi	EXPLOITABLE (Admin gained)	REMEDIATED (Blocked)	PASS
VULN-002	UNION Data Theft	EXPLOITABLE (9 leaked)	REMEDIATED (0 leaked)	PASS
VULN-003	Numeric Tautology	EXPLOITABLE (Dumped all)	REMEDIATED (Blocked)	PASS
VULN-004	Missing Security Headers	EXPLOITABLE (Missing HSTS/CSP)	REMEDIATED (Injected)	PASS
VULN-005	Server Banner Disclosure	EXPLOITABLE (Werkzeug exposed)	REMEDIATED (Sanitized)	PASS

5. Cryptographic Evidence Chain (SHA-256)

Evidence ID	Phase / Artifact	Module	SHA-256 Checksum
EV-SQLI-001	EV-SQLI-001_auth_bypass.md	Assignment-01-SQLi	87f7b1b7b4a7a7f762bec1042e2196ad...
EV-SQLI-002	EV-SQLI-002_union_extract.md	Assignment-01-SQLi	2cc64a5d0f04e1f65f63f0f0565de050...
EV-SQLI-003	EV-SQLI-003_blind_boolean.md	Assignment-01-SQLi	c5a349d3e0b74b0507e3d02c2d89aa5a...
EV-ENUM-001	EV-ENUM-001_dir_fuzzing.md	Assignment-02-EthicalHacking	6444ddb362a20ed8af9036a6ab8642b0...
EV-EXPLOIT-001	EV-EXPLOIT-001_poc_auth.md	Assignment-02-EthicalHacking	5ff3ef335f5f8084c84ce2858865c94a...
EV-RECON-001	EV-RECON-001_whois_dns.md	Assignment-02-EthicalHacking	4bc5ebd46d5a7cc9aaa3e8c31fdb526b...
EV-RETEST-001	EV-RETEST-001_post_patch.md	Assignment-02-EthicalHacking	210f14c4663554eaa4e25d582a35e80d...
EV-SCAN-001	EV-SCAN-001_nmap_full.md	Assignment-02-EthicalHacking	44b5ea57dcc7fa46808599ae2e59bdfd...